

Лабораторная работа №4.1

Предотвращение сетевых атак с повреждением таблицы ARP для среды без использования DHCP

Цель работы

Целью данной лабораторной работы является изучение механизма предотвращения аномального ARP-трафика посредством функции безопасности Dynamic ARP Inspection (DAI) на коммутаторе Cisco в локальной сети без использования протокола DHCP.

Задачи работы

В ходе выполнения работы решались следующие задачи: подготовка рабочей среды на базе виртуальной топологии EVE-NG, назначение статических IP-адресов узлам сети, настройка списка контроля доступа ARP и механизма динамической проверки ARP на коммутаторе, а также генерация и фильтрация четырёх типов аномальных ARP-сообщений с проверкой соответствующих механизмов фильтрации коммутатора.

Ход работы

Подготовка рабочей среды

В среде эмуляции EVE-NG была развёрнута сетевая топология, включающая два узла под управлением операционной системы Windows (узлы А и В), узел под управлением Kali Linux (узел С, выступающий в качестве вредоносного), а также коммутатор Switch (образ Cisco IOL, заменяющий Cisco Catalyst 2960; порты в указанном образе обозначаются как Ethernet0/x вместо GigabitEthernet0/x). Узел А подключён к коммутатору через порт Ethernet0/2, узел В — через порт Ethernet0/3, узел С — через порт Ethernet0/1.

Назначение статических IP-адресов

Узлам сети были назначены статические IP-адреса из подсети 192.168.1.0/24: узлу А — 192.168.1.2, узлу В — 192.168.1.3, узлу С — 192.168.1.4. На узлах под управлением Windows назначение IP-адресов выполнено через свойства протокола TCP/IPv4 сетевого адаптера, на узле С — командой `ip addr add 192.168.1.4/24 dev eth0`. Корректность назначения адресов подтверждена на каждом узле командами `ipconfig` и `ip addr show`. Зафиксированы MAC-адреса узлов: 50-00-00-03-00-00 для узла А, 50-00-00-04-00-00 для узла В и 00:50:00:00:02:00 для узла С (в Cisco-формате — 5000.0003.0000, 5000.0004.0000 и 0050.0000.0200 соответственно).

Настройка динамической проверки ARP

На коммутаторе Switch командой `enable` осуществлён переход в привилегированный режим, после чего командой `configure terminal` был выполнен переход в режим глобальной конфигурации. Командой `ip arp inspection vlan 1` механизм динамической проверки ARP был включён для VLAN 1, командой `ip arp inspection vlan 1 logging acl-match matchlog` была активирована запись событий ACL-фильтрации в журнал коммутатора.

Для имеющейся сетевой топологии был создан список контроля доступа ARP с именем ARPINSPECT, содержащий три разрешающих правила для легитимных сопоставлений IP- и MAC-адресов узлов А, В и С, а также запрещающее правило для всех остальных сочетаний. Созданный список был привязан к VLAN 1 в качестве статического фильтра командой `ip arp inspection filter ARPINSPECT vlan 1 static`. Корректность настройки подтверждена командой `show arp access-list`, вывод которой представлен на рис. 1.

```
ARP access list ARPINSPECT
permit ip host 192.168.1.2 mac host 5000.0003.0000 log
permit ip host 192.168.1.3 mac host 5000.0004.0000 log
permit ip host 192.168.1.4 mac host 5000.0000.0200 log
deny ip any mac any log

Switch#show ip arp inspection vlan1
^
% Invalid input detected at '^' marker.

Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#no arp access-list ARPINSPECT
Switch(config)#arp access-list ARPINSPECT
Switch(config-arp-nacl)# permit ip host 192.168.1.2 mac host 5000.0003.0000
$host 192.168.1.2 mac host 5000.0003.0000 log
Switch(config-arp-nacl)#permit ip host 192.168.1.3 mac host 5000.0004.0000
$host 192.168.1.3 mac host 5000.0004.0000 log
Switch(config-arp-nacl)# permit ip host 192.168.1.4 mac host 0050.0000.0200
$host 192.168.1.4 mac host 0050.0000.0200 log
Switch(config-arp-nacl)#deny ip any mac any log
Switch(config-arp-nacl)#exit
Switch(config)#^Z
Switch#
*May 17 06:28:13.445: %SYS-5-CONFIG_I: Configured from console by console
Switch#show arp access-list
ARP access list ARPINSPECT
permit ip host 192.168.1.2 mac host 5000.0003.0000 log
permit ip host 192.168.1.3 mac host 5000.0004.0000 log
permit ip host 192.168.1.4 mac host 0050.0000.0200 log
deny ip any mac any log

Switch#show ip arp inspection vlan 1

Source Mac Validation      : Enabled
Destination Mac Validation : Enabled
IP Address Validation      : Enabled

Vlan    Configuration      Operation    ACL Match      Static ACL
----    -
1       Enabled            Active      ARPINSPECT     Yes

Vlan    ACL Logging            DHCP Logging  Probe Logging
----    -
1       Acl-Match                Deny          Off

Switch#
```

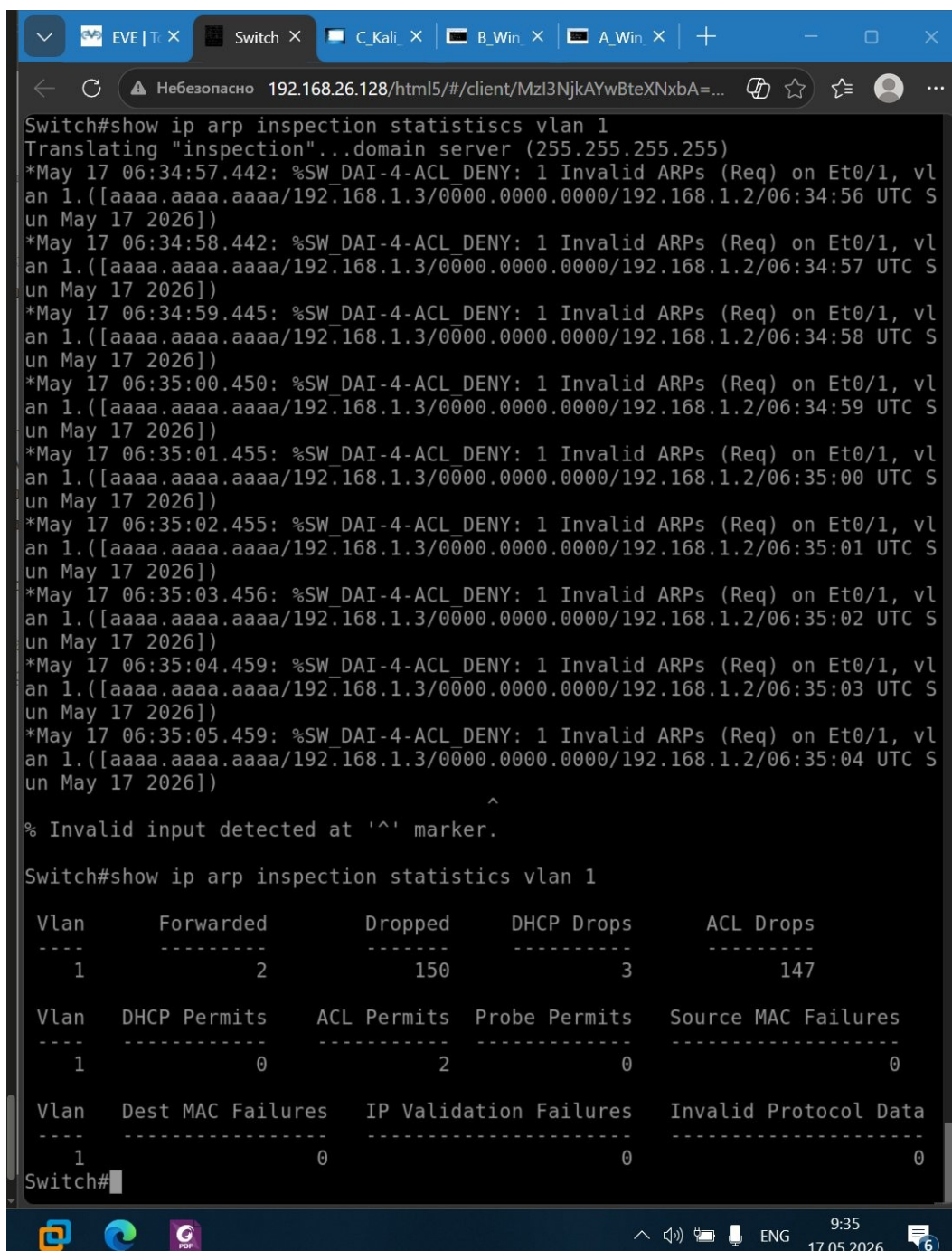
Рис. 1. Список ACL ARPINSPECT, привязанный к механизму DAI

Дополнительно командой `ip arp inspection validate src-mac dst-mac ip` была активирована расширенная проверка корректности кадров ARP, включающая проверку соответствия MAC-адреса источника в заголовке Ethernet MAC-адресу источника в заголовке ARP-сообщения, аналогичную проверку для MAC-

адресов назначения, а также проверку заголовков ARP-сообщений на наличие недействительных IP-адресов (0.0.0.0, 255.255.255.255 и адресов многоадресной рассылки). Размер журнала событий установлен в 200 записей командой `ip arp inspection log-buffer entries 200`. Конфигурация и текущее состояние процесса динамической проверки ARP подтверждены командой `show ip arp inspection vlan 1`: проверки Source Mac Validation, Destination Mac Validation и IP Address Validation активированы, статус механизма — Active, в качестве привязанного списка контроля доступа указан ARPINSPECT.

Генерация и фильтрация аномальных сообщений ARP

Сообщение №1. На узле С средствами утилиты `arping` было сформировано и отправлено аномальное широковещательное сообщение ARP-запроса командой `arping 192.168.1.2 -S 192.168.1.3 -s aa:aa:aa:aa:aa:aa`. Указанное сообщение противоречит существующим сопоставлениям IP-МАС-адресов, так как пара адресов источника (192.168.1.3, aa:aa:aa:aa:aa:aa) не входит в список разрешённых правил списка контроля доступа ARPINSPECT. После запуска отправки ответы от узла А перестали поступать, в выводе `arping` отображались сообщения Timeout, что свидетельствует о фильтрации указанного ARP-трафика коммутатором (рис. 2).



```
Switch#show ip arp inspection statistics vlan 1
Translating "inspection"...domain server (255.255.255.255)
*May 17 06:34:57.442: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:34:56 UTC S
un May 17 2026])
*May 17 06:34:58.442: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:34:57 UTC S
un May 17 2026])
*May 17 06:34:59.445: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:34:58 UTC S
un May 17 2026])
*May 17 06:35:00.450: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:34:59 UTC S
un May 17 2026])
*May 17 06:35:01.455: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:35:00 UTC S
un May 17 2026])
*May 17 06:35:02.455: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:35:01 UTC S
un May 17 2026])
*May 17 06:35:03.456: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:35:02 UTC S
un May 17 2026])
*May 17 06:35:04.459: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:35:03 UTC S
un May 17 2026])
*May 17 06:35:05.459: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Req) on Et0/1, vl
an 1.([aaaa.aaaa.aaaa/192.168.1.3/0000.0000.0000/192.168.1.2/06:35:04 UTC S
un May 17 2026])
% Invalid input detected at '^' marker.

Switch#show ip arp inspection statistics vlan 1

Vlan      Forwarded      Dropped      DHCP Drops      ACL Drops
----      -
1          2              150          3               147

Vlan      DHCP Permits    ACL Permits    Probe Permits    Source MAC Failures
----      -
1          0              2              0               0

Vlan      Dest MAC Failures  IP Validation Failures  Invalid Protocol Data
----      -
1          0              0                  0

Switch#
```

Рис. 3. Статистика фильтрации ARP-сообщений после Сообщения №1

Сообщение №2. На узле С средствами утилиты arpspoof было сформировано и отправлено anomальное сообщение ARP-ответа на узел А командой `arpspoof -i eth0 -t 192.168.1.2 192.168.1.3`. Указанное сообщение содержит недопустимую пару адресов источника (192.168.1.3, 00:50:00:00:02:00), что соответствует классической технике атаки повреждения ARP-таблицы (MitM): IP-адрес источника принадлежит узлу В, а MAC-адрес —

A screenshot of a Kali Linux desktop environment. The top panel shows several open web browser tabs labeled "EVE | T...", "Switch X", "C_Kali X", "B_Win X", and "A_Win X". Below the tabs is a navigation bar with icons for back, forward, and search, along with a security warning icon and the URL "192.168.26.128/html5/#/client/Mzi3NzAAyWbteXNxbA==?t...". The main workspace area has a top status bar displaying "Activities", "Applications", "Places", "Terminal", and the date/time "May 17 02:38". On the left side, there is a vertical dock containing icons for various applications like Firefox, LibreOffice, and others. In the center, a terminal window titled "root@kali: ~" is open, showing the output of an ARP spoofing attack. The terminal text includes a timeout message, statistics for 192.168.1.2, and a series of log entries showing successful ARP replies from 192.168.1.3 to various MAC addresses. The terminal also shows commands being entered by the user.

Статистика отфильтрованных ARP-сообщений после Сообщения №2 представлена на рис. 5. По сравнению с предыдущим замером счётчик ACL Drops увеличился на 10 единиц (147 → 157), что соответствует кадрам arpspoof, отброшенным по списку ARPINSPECT из-за недопустимой пары источника. Дополнительно зафиксировано появление 5 кадров в счётчике Source MAC Failures: эти кадры были отправлены в фазе cleanup arpspoof и содержали

легитимный MAC-адрес узла В (5000.0004.0000) в заголовке ARP-сообщения, что прошло проверку по ACL, однако MAC-адрес источника в заголовке Ethernet кадра оставался MAC-адресом узла С (0050.0000.0200), что и было выявлено механизмом проверки соответствия src-mac. Поведение полностью соответствует ожидаемому: ACL-фильтрация и проверка src-mac срабатывают независимо друг от друга.

```

*May 17 06:37:34.071: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Res) on Et0/1, vl
an 1.([0050.0000.0200/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:33 UTC S
un May 17 2026])
Switch#
*May 17 06:37:36.079: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Res) on Et0/1, vl
an 1.([0050.0000.0200/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:35 UTC S
un May 17 2026])
Switch#
*May 17 06:37:38.084: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Res) on Et0/1, vl
an 1.([0050.0000.0200/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:37 UTC S
un May 17 2026])
Switch#
*May 17 06:37:40.097: %SW_DAI-4-ACL_DENY: 1 Invalid ARPs (Res) on Et0/1, vl
an 1.([0050.0000.0200/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:39 UTC S
un May 17 2026])
*May 17 06:37:41.102: %SW_DAI-4-INVALID_ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([5000.0004.0000/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:40 UT
C Sun May 17 2026])
Switch#
*May 17 06:37:42.107: %SW_DAI-4-INVALID_ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([5000.0004.0000/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:41 UT
C Sun May 17 2026])
*May 17 06:37:43.111: %SW_DAI-4-INVALID_ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([5000.0004.0000/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:42 UT
C Sun May 17 2026])
Switch#
*May 17 06:37:44.115: %SW_DAI-4-INVALID_ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([5000.0004.0000/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:43 UT
C Sun May 17 2026])
*May 17 06:37:45.120: %SW_DAI-4-INVALID_ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([5000.0004.0000/192.168.1.3/5000.0003.0000/192.168.1.2/06:37:44 UT
C Sun May 17 2026])
Switch#show ip arp inspection statistics vlan 1

Vlan      Forwarded      Dropped      DHCP Drops      ACL Drops
----      -
1          2              165          3              157

Vlan      DHCP Permits    ACL Permits    Probe Permits    Source MAC Failures
----      -
1          0              2              0              5

Vlan      Dest MAC Failures  IP Validation Failures  Invalid Protocol Data
----      -
1          0              0              0              0
Switch#

```

Рис. 5. Статистика фильтрации ARP-сообщений после Сообщения №2

Сообщение №3. На узле С средствами утилиты `arping` был сформирован и отправлен аномальный широковещательный ARP-ответ командой `arping -i eth0 -B -P`. Указанное сообщение содержит в качестве IP-адреса назначения адрес 255.255.255.255, который по соглашению протокола ARP не может выступать в роли адреса назначения и относится к недопустимым в смысле проверки IP Validation механизма DAI. При этом пара адресов источника (192.168.1.4, 00:50:00:00:02:00) является легитимной по списку ARPINSPECT, что обеспечивает прохождение кадра через этап ACL-фильтрации (рис. 6).

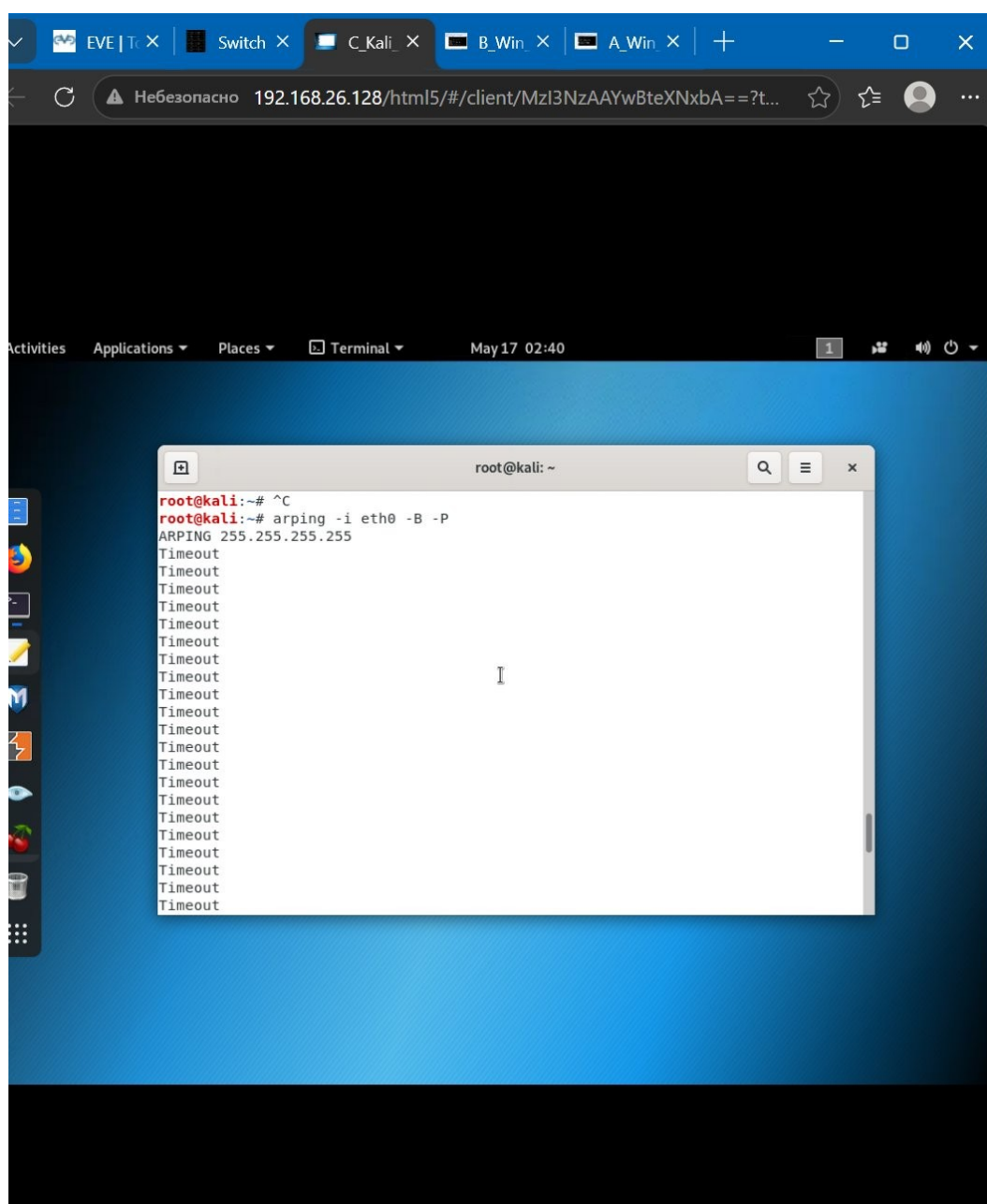
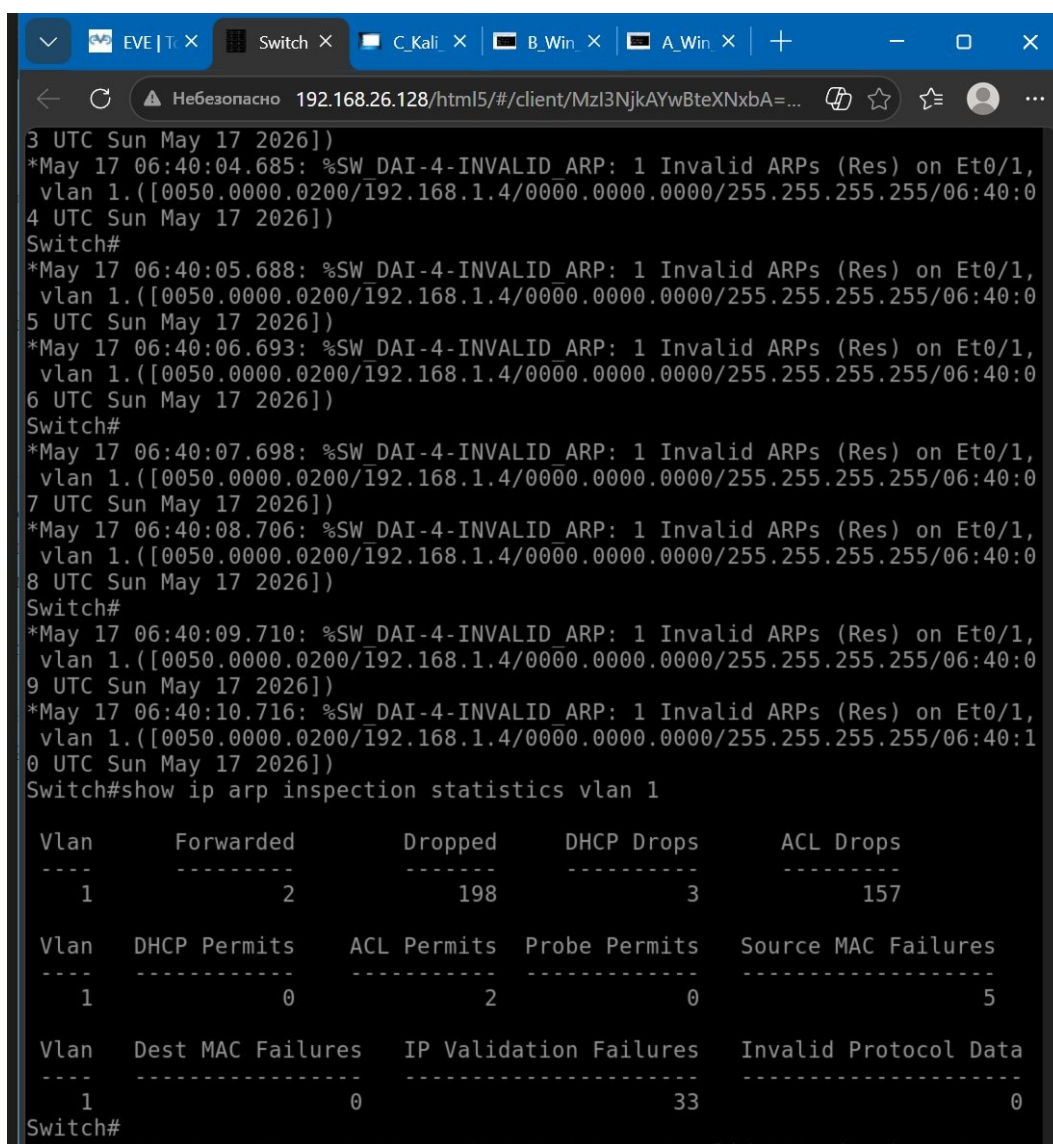


Рис. 6. Отправка широковещательного ARP-ответа на адрес 255.255.255.255

Статистика отфильтрованных ARP-сообщений после Сообщения №3 представлена на рис. 7. Все 33 отправленных кадра попали в счётчик IP Validation Failures, что подтверждает фильтрацию указанных аномальных кадров именно по механизму проверки корректности IP-адресов в заголовке ARP-сообщения. Счётчики ACL Drops и Source MAC Failures приростом не пополнились, что подтверждает корректность работы независимых механизмов проверки DAI.



```
3 UTC Sun May 17 2026]]
*May 17 06:40:04.685: %SW_DAI-4-INVALID ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/0000.0000.0000/255.255.255.255/06:40:0
4 UTC Sun May 17 2026]]
Switch#
*May 17 06:40:05.688: %SW_DAI-4-INVALID ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/0000.0000.0000/255.255.255.255/06:40:0
5 UTC Sun May 17 2026]]
*May 17 06:40:06.693: %SW_DAI-4-INVALID ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/0000.0000.0000/255.255.255.255/06:40:0
6 UTC Sun May 17 2026]]
Switch#
*May 17 06:40:07.698: %SW_DAI-4-INVALID ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/0000.0000.0000/255.255.255.255/06:40:0
7 UTC Sun May 17 2026]]
*May 17 06:40:08.706: %SW_DAI-4-INVALID ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/0000.0000.0000/255.255.255.255/06:40:0
8 UTC Sun May 17 2026]]
Switch#
*May 17 06:40:09.710: %SW_DAI-4-INVALID ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/0000.0000.0000/255.255.255.255/06:40:0
9 UTC Sun May 17 2026]]
*May 17 06:40:10.716: %SW_DAI-4-INVALID ARP: 1 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/0000.0000.0000/255.255.255.255/06:40:1
0 UTC Sun May 17 2026]]
Switch#show ip arp inspection statistics vlan 1

Vlan      Forwarded      Dropped      DHCP Drops      ACL Drops
----      -
1          2              198          3              157

Vlan      DHCP Permits    ACL Permits    Probe Permits    Source MAC Failures
----      -
1          0              2              0              5

Vlan      Dest MAC Failures    IP Validation Failures    Invalid Protocol Data
----      -
1          0                    33                        0

Switch#
```

Рис. 7. Статистика фильтрации ARP-сообщений после Сообщения №3

Сообщение №4. Самостоятельная часть задания методических указаний предусматривала генерацию аномального ARP-ответа, в котором MAC-адрес источника в заголовке ARP-сообщения отличается от MAC-адреса источника в заголовке Ethernet, и подтверждение его фильтрации механизмом Source MAC Failures. Поскольку штатная утилита `arping` в системе Kali Linux не позволяет независимо задавать MAC-адрес источника на уровне Ethernet и на уровне ARP-payload (ключ `-s` одновременно подменяет оба значения), для решения задачи была использована библиотека Scapy. На узле С в интерактивной оболочке Scapy была введена команда формирования и отправки кадра ARP-ответа, в котором MAC-адрес источника в заголовке Ethernet установлен в значение `aa:aa:aa:aa:aa:aa`, а MAC-адрес источника в заголовке ARP — в значение `00:50:00:00:02:00` (легитимный MAC-адрес узла С). Цель сообщения — узел В (`192.168.1.3`, `50:00:00:04:00:00`). Параметры команды: количество кадров — 30, интервал отправки — 0,3 с. Вывод Scapy подтвердил успешную отправку 30 кадров (рис. 8).

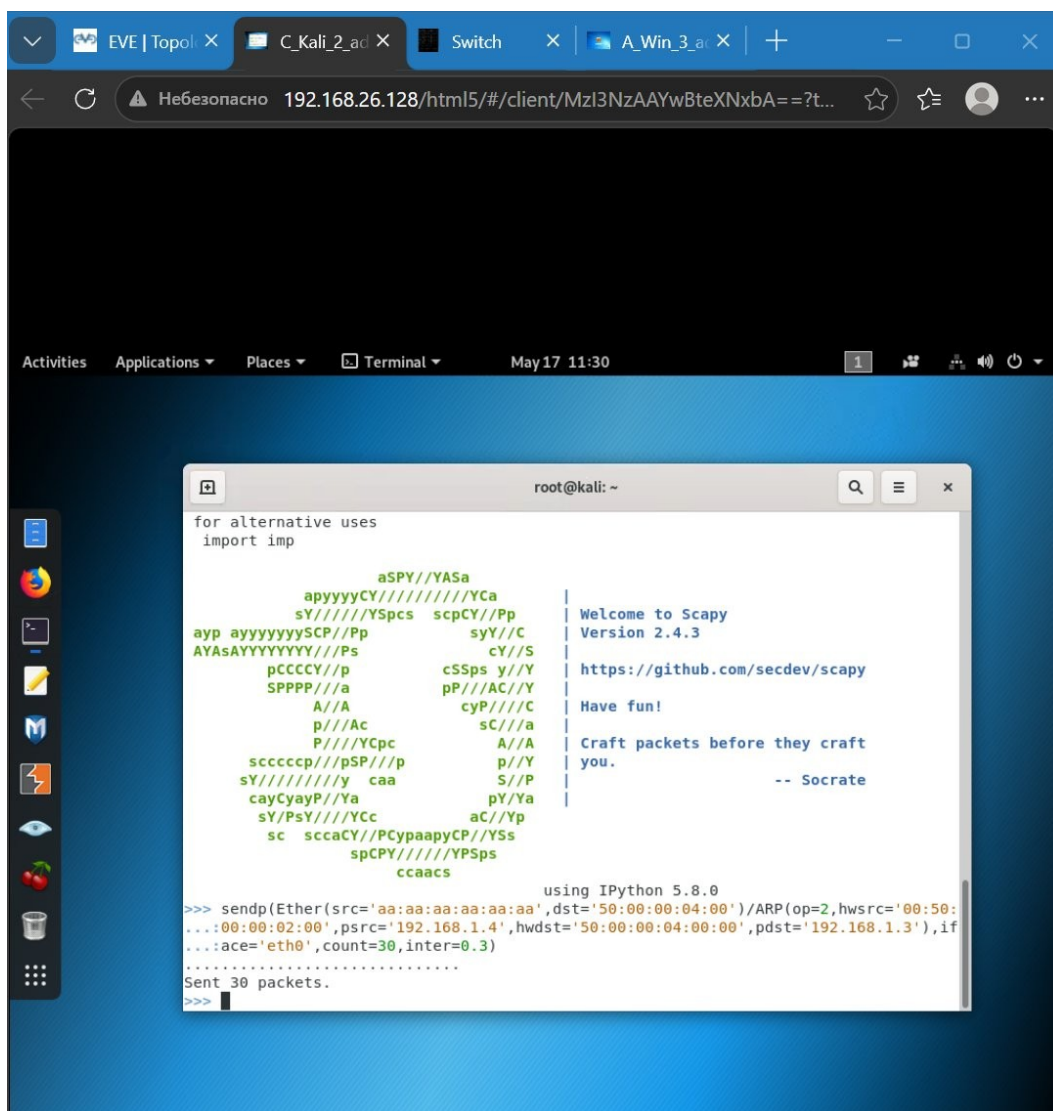


Рис. 8. Формирование и отправка аномального ARP-ответа средствами Scapy

Статистика отфильтрованных ARP-сообщений после Сообщения №4 представлена на рис. 9. Зафиксировано 30 кадров в счётчике Source MAC Failures, что точно соответствует количеству отправленных кадров и подтверждает фильтрацию указанных аномальных сообщений именно механизмом проверки соответствия source-MAC. Прирост в счётчиках ACL Drops и IP Validation Failures отсутствует. В журнале коммутатора зафиксированы записи вида %SW_DAI-4-INVALID_ARP с указанием значений MAC-адресов в заголовке Ethernet и в ARP-payload, демонстрирующих установленное несоответствие.

```
Switch#
*May 17 15:29:38.918: %SW DAI-4-INVALID_ARP: 3 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:38 UT
C Sun May 17 2026])
*May 17 15:29:39.926: %SW DAI-4-INVALID_ARP: 3 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:39 UT
C Sun May 17 2026])
Switch#
*May 17 15:29:40.932: %SW DAI-4-INVALID_ARP: 4 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:40 UT
C Sun May 17 2026])
*May 17 15:29:41.940: %SW DAI-4-INVALID_ARP: 3 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:41 UT
C Sun May 17 2026])
Switch#
*May 17 15:29:42.944: %SW DAI-4-INVALID_ARP: 3 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:42 UT
C Sun May 17 2026])
*May 17 15:29:43.951: %SW DAI-4-INVALID_ARP: 4 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:43 UT
C Sun May 17 2026])
Switch#
*May 17 15:29:44.954: %SW DAI-4-INVALID_ARP: 3 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:44 UT
C Sun May 17 2026])
*May 17 15:29:45.961: %SW DAI-4-INVALID_ARP: 3 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:45 UT
C Sun May 17 2026])
Switch#
*May 17 15:29:46.969: %SW DAI-4-INVALID_ARP: 4 Invalid ARPs (Res) on Et0/1,
vlan 1.([0050.0000.0200/192.168.1.4/5000.0004.0000/192.168.1.3/15:29:46 UT
C Sun May 17 2026])
Switch#show ip arp inspection statistics vlan 1

Vlan      Forwarded      Dropped      DHCP Drops      ACL Drops
----      -
1          2              30           0               0

Vlan      DHCP Permits    ACL Permits    Probe Permits    Source MAC Failures
----      -
1          0              2             0               30

Vlan      Dest MAC Failures    IP Validation Failures    Invalid Protocol Data
----      -
1          0                   0                         0

Switch#
```

Рис. 9. Статистика фильтрации ARP-сообщений после Сообщения №4

Вывод

В ходе выполнения лабораторной работы был изучен механизм обеспечения безопасности Dynamic ARP Inspection коммутаторов Cisco для среды без использования DHCP, основанный на ручном задании списка контроля доступа ARP, а также механизмы расширенной проверки

корректности ARP-сообщений. На коммутаторе был сконфигурирован список ARPINSPECT с тремя разрешающими правилами для легитимных сопоставлений IP- и MAC-адресов узлов сети и запрещающим правилом deny ip any mac any log, активированы проверки соответствия MAC-адресов в заголовках Ethernet и ARP, а также проверка корректности IP-адресов в заголовке ARP-сообщения.

Экспериментально подтверждена эффективность настроенных механизмов фильтрации применительно к четырём типам аномальных ARP-сообщений. Аномальные ARP-запросы с подменой пары IP-MAC источника и аномальные ARP-ответы, формируемые утилитой arpspoof, отбрасываются механизмом ACL Drops по правилу deny ip any mac any log списка ARPINSPECT. Аномальные ARP-ответы с недопустимым IP-адресом назначения (255.255.255.255) отбрасываются механизмом IP Validation Failures, при этом ACL-фильтрация пропускает указанные кадры в связи с корректной парой адресов источника. Аномальные ARP-ответы, в которых MAC-адрес источника в заголовке Ethernet не соответствует MAC-адресу источника в заголовке ARP-сообщения, отбрасываются механизмом Source MAC Failures: данный тип кадров был самостоятельно сгенерирован средствами библиотеки Scapy на узле С, поскольку штатная утилита arping не позволяет независимо задавать значения MAC-адреса источника в указанных заголовках.

В процессе выполнения лабораторной работы практически продемонстрирована способность коммутатора Cisco при корректной настройке Dynamic ARP Inspection обнаруживать и фильтровать аномальный ARP-трафик различных типов в локальной сети без использования протокола DHCP, обеспечивая защиту узлов сети от атак повреждения ARP-таблиц, реализуемых посредством типичных программных средств.

Контрольные вопросы

1. Может ли запрос ARP быть одноадресным? Почему?

Да, запрос ARP может быть одноадресным. Стандартный запрос ARP (ARP request, op=1) направлен на установление соответствия известного IP-адреса и неизвестного MAC-адреса целевого узла, в связи с чем традиционно отправляется на широковещательный MAC-адрес ff:ff:ff:ff:ff:ff. Тем не менее протокол ARP допускает одноадресные запросы, которые используются, в частности, для подтверждения актуальности существующей записи в ARP-таблице узла без её повторного разрешения, а также в рамках механизма Probe ARP, описанного в RFC 5227, для проверки уникальности назначаемого IP-адреса в сети.

2. Может ли ответ ARP быть широковещательным? Почему?

Да, ответ ARP может быть широковещательным. Стандартный ответ ARP (ARP reply, op=2) формируется в результате обработки полученного запроса и адресуется одноадресно тому узлу, который инициировал запрос — его MAC-адрес известен из поля Sender Hardware Address ARP-запроса. Однако протокол ARP допускает разновидность ответа, называемую gratuitous ARP reply, которая формируется узлом самостоятельно (без получения соответствующего запроса) и отправляется на широковещательный MAC-адрес ff:ff:ff:ff:ff:ff. Указанная разновидность ответа используется для одновременного оповещения всех узлов сегмента сети о сопоставлении IP- и MAC-адресов отправителя — например, при включении узла в сеть, при смене MAC-адреса сетевого интерфейса либо при срабатывании механизмов резервирования адресов. В лабораторной работе широковещательные ARP-ответы формировались утилитой arping с ключом -B в составе Сообщения №3.

3. Почему аномальные запросы ARP могут представлять угрозу?

Аномальные ARP-запросы могут представлять угрозу в связи с архитектурными особенностями протокола ARP, не предусматривающими проверки достоверности передаваемых сопоставлений IP- и MAC-адресов.

Любой узел локальной сети, получивший ARP-запрос с заданной парой адресов источника, записывает указанное сопоставление в собственную ARP-таблицу без какой-либо аутентификации источника. Нарушитель может воспользоваться указанной особенностью для повреждения ARP-таблиц узлов-жертв путём отправки множества аномальных ARP-запросов с подменёнными парами адресов, что позволяет ему реализовать атаки типа отказ в обслуживании (DoS — нарушение связности между узлами) или человек посередине (MitM — перенаправление трафика жертвы через атакующий узел с возможностью перехвата и модификации). Кроме того, аномальные ARP-запросы могут содержать недействительные значения адресов (адрес 0.0.0.0 в поле IP-источника, широковещательный MAC-адрес в поле MAC-источника), что нарушает корректную работу узлов сети и сетевых протоколов более высокого уровня.

4. Что собой представляет шторм запросов ARP и для чего он используется нарушителями?

Шторм запросов ARP представляет собой атаку канального уровня, заключающуюся в массовой широковещательной отправке ARP-запросов в локальную сеть в течение короткого промежутка времени. Атака может быть направлена как на конкретный узел-жертву, так и на всю локальную сеть в целом. Нарушители используют ARP-шторм для нескольких целей: для одновременного повреждения ARP-таблиц большого количества узлов сети, что приводит к нарушению связности и реализации массовой DoS-атаки; для создания значительной фоновой нагрузки на сетевые устройства (коммутаторы, маршрутизаторы и узлы), вынужденные обрабатывать каждое поступающее ARP-сообщение, что приводит к снижению производительности и потенциально — к самопроизвольной перезагрузке перегруженных устройств; для сокрытия других, более точечных атак (например, целенаправленного MitM или эксфильтрации данных) под массовым потоком аномального трафика; а

также для проведения сетевой разведки путём анализа ответов узлов и определения активных IP-адресов в сегменте.

Лабораторная работа №4.2

Предотвращение сетевых атак с повреждением таблицы ARP для среды с использованием DHCP

Цель работы

Целью данной лабораторной работы является изучение механизма предотвращения аномального ARP-трафика посредством совместного применения функций безопасности Dynamic ARP Inspection и DHCP Snooping коммутатора Cisco в локальной сети с использованием протокола DHCP.

Задачи работы

В ходе выполнения работы решались следующие задачи: подготовка рабочей среды на базе виртуальной топологии EVE-NG с маршрутизатором в роли легитимного DHCP-сервера, запуск механизма DHCP Snooping на коммутаторе с обозначением порта подключения DHCP-сервера в качестве доверенного, настройка динамической проверки ARP без использования статического списка контроля доступа, а также генерация и фильтрация аномальных сообщений ARP и DHCP с проверкой соответствующих механизмов фильтрации.

Ход работы

Подготовка рабочей среды

В среде EVE-NG была развёрнута сетевая топология, включающая узел под управлением операционной системы Windows (узел А), узел под управлением Kali Linux (узел С, выступающий в качестве вредоносного), коммутатор Switch (образ Cisco IOL) и маршрутизатор Router (образ Cisco IOS), выполняющий функцию легитимного DHCP-сервера. Узел А подключён к

коммутатору через порт Ethernet0/2, узел С — через порт Ethernet0/1, маршрутизатор — через порт Ethernet0/0 (рис. 1).

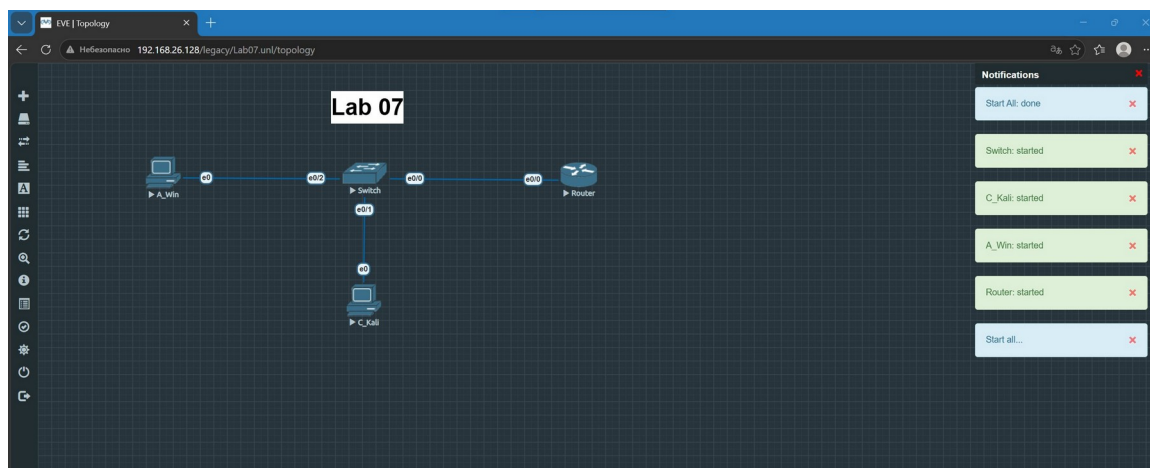
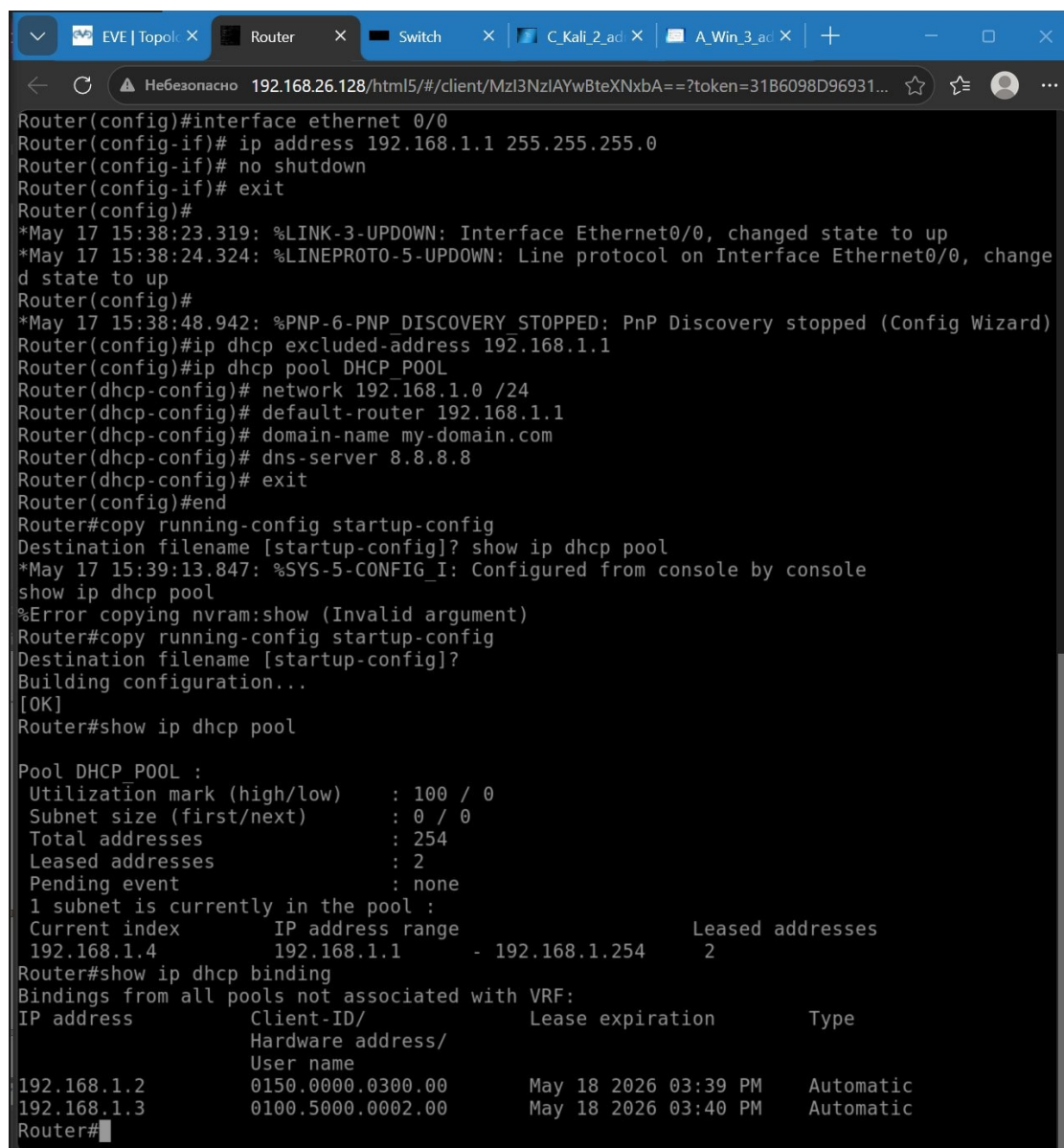


Рис. 1. Сетевая топология лабораторной работы №4.2

Настройка легитимного DHCP-сервера

На маршрутизаторе Router была установлена консоль управления, после чего на интерфейсе Ethernet0/0 командой `ip address 192.168.1.1 255.255.255.0` был назначен IP-адрес 192.168.1.1/24 и интерфейс переведён в активное состояние командой `no shutdown`. Далее был сконфигурирован пул адресов DHCP с именем DHCP_POOL: командой `network 192.168.1.0 /24` задан диапазон выдаваемых адресов, командой `default-router 192.168.1.1` — адрес шлюза по умолчанию, командой `domain-name my-domain.com` — доменное имя, командой `dns-server 8.8.8.8` — адрес DNS-сервера. Адрес 192.168.1.1 был исключён из пула командой `ip dhcp excluded-address 192.168.1.1`. Корректность настройки подтверждена выводом команды `show ip dhcp pool` и `show ip dhcp binding` (рис. 2).



```
Router(config)#interface ethernet 0/0
Router(config-if)# ip address 192.168.1.1 255.255.255.0
Router(config-if)# no shutdown
Router(config-if)# exit
Router(config)#
*May 17 15:38:23.319: %LINK-3-UPDOWN: Interface Ethernet0/0, changed state to up
*May 17 15:38:24.324: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/0, change
d state to up
Router(config)#
*May 17 15:38:48.942: %PNP-6-PNP_DISCOVERY_STOPPED: PnP Discovery stopped (Config Wizard)
Router(config)#ip dhcp excluded-address 192.168.1.1
Router(config)#ip dhcp pool DHCP_POOL
Router(dhcp-config)# network 192.168.1.0 /24
Router(dhcp-config)# default-router 192.168.1.1
Router(dhcp-config)# domain-name my-domain.com
Router(dhcp-config)# dns-server 8.8.8.8
Router(dhcp-config)# exit
Router(config)#end
Router#copy running-config startup-config
Destination filename [startup-config]? show ip dhcp pool
*May 17 15:39:13.847: %SYS-5-CONFIG_I: Configured from console by console
show ip dhcp pool
%Error copying nvram:show (Invalid argument)
Router#copy running-config startup-config
Destination filename [startup-config]?
Building configuration...
[OK]
Router#show ip dhcp pool

Pool DHCP_POOL :
Utilization mark (high/low)      : 100 / 0
Subnet size (first/next)         : 0 / 0
Total addresses                   : 254
Leased addresses                  : 2
Pending event                     : none
1 subnet is currently in the pool :
Current index      IP address range      Leased addresses
192.168.1.4        192.168.1.1 - 192.168.1.254      2
Router#show ip dhcp binding
Bindings from all pools not associated with VRF:
IP address          Client-ID/
                    Hardware address/
                    User name
192.168.1.2          0150.0000.0300.00      May 18 2026 03:39 PM      Automatic
192.168.1.3          0100.5000.0002.00      May 18 2026 03:40 PM      Automatic
Router#
```

Рис. 2. Параметры легитимного DHCP-сервера и таблица выданных IP-адресов

На узлах А и С сетевой адаптер переведён в режим автоматического получения IP-адреса. Командой `ipconfig /all` на узле А подтверждено получение IP-адреса 192.168.1.2 от легитимного DHCP-сервера с MAC-адресом 50-00-00-03-00-00 (рис. 3), командой `ip addr show eth0` на узле С — получение IP-адреса 192.168.1.3 с MAC-адресом 00:50:00:00:02:00 (рис. 4).

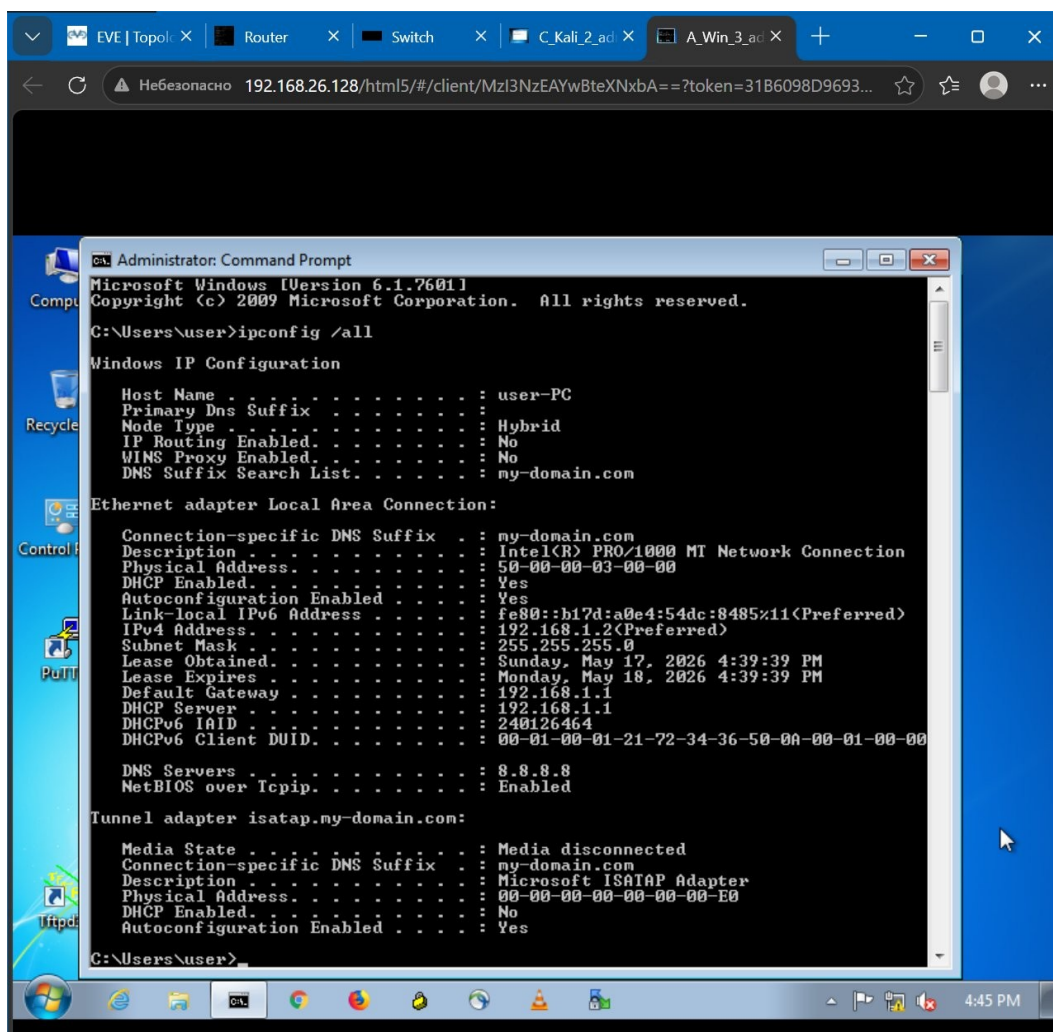


Рис. 3. IP-адрес узла А, полученный от легитимного DHCP-сервера

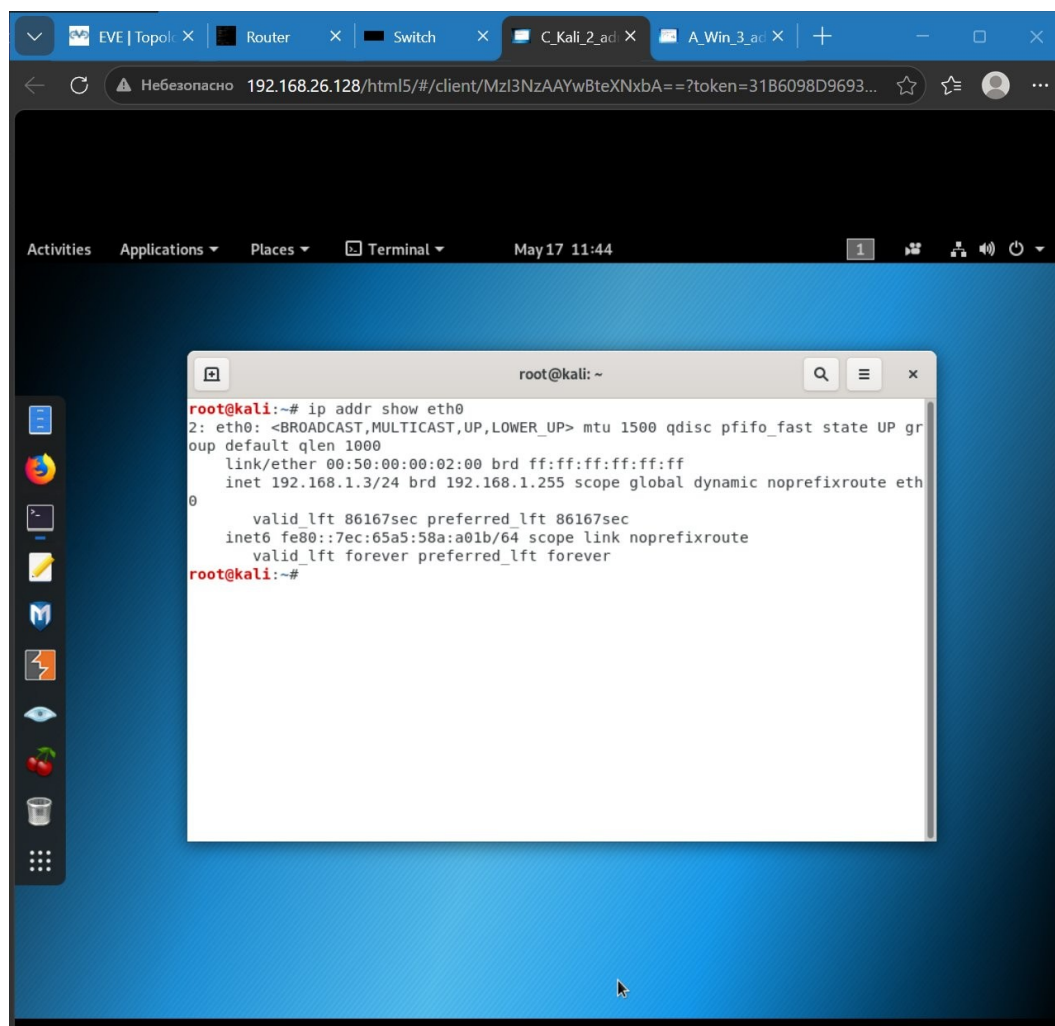


Рис. 4. IP-адрес узла C, полученный от легитимного DHCP-сервера

Запуск механизма DHCP Snooping

На коммутаторе Switch командой `ip dhcp snooping` механизм DHCP Snooping был включён глобально, командой `ip dhcp snooping vlan 1` — активирован для VLAN 1, командой `no ip dhcp snooping information option` отключена вставка опции 82 в DHCP-кадры. На порт Ethernet0/0, к которому подключён маршрутизатор-DHCP-сервер, командами `ip dhcp snooping trust` и `ip arp inspection trust` присвоен статус доверенного одновременно для механизмов DHCP Snooping и Dynamic ARP Inspection. Конфигурация сохранена в энергонезависимой памяти коммутатора командой `copy running-config startup-config`.

После перезагрузки узлов А и С сетевые интерфейсы повторно прошли процедуру получения IP-адресов по протоколу DHCP, в результате чего коммутатор Switch наполнил свою базу данных сопоставлений DHCP Snooping. Состояние базы данных подтверждено командой `show ip dhcp snooping binding` и представлено на рис. 5: зафиксированы две легитимные записи — 192.168.1.2 с MAC-адресом 50:00:00:03:00:00 на интерфейсе Ethernet0/2 (узел А) и 192.168.1.3 с MAC-адресом 00:50:00:00:02:00 на интерфейсе Ethernet0/1 (узел С).

```

Vlan      Configuration      Operation      ACL Match      Static ACL
-----
1         Enabled                Active
Vlan      ACL Logging             DHCP Logging    Probe Logging
-----
1         Deny                   Deny            Off
Switch#show ip dhcp snooping
Switch DHCP snooping is enabled
Switch DHCP gleaning is disabled
DHCP snooping is configured on following VLANs:
1
DHCP snooping is operational on following VLANs:
1
DHCP snooping is configured on the following L3 Interfaces:
Insertion of option 82 is disabled
  circuit-id default format: vlan-mod-port
  remote-id: aabb.cc00.1000 (MAC)
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Verification of giaddr field is enabled
DHCP snooping trust/rate is configured on the following Interfaces:
Interface      Trusted      Allow option    Rate limit (pps)
-----
Ethernet0/0    yes          yes             unlimited
  Custom circuit-ids:
Switch#show ip dhcp snooping binding
MacAddress      IPAddress      Lease(sec)      Type            VLAN      Interface
-----
Total number of bindings: 0

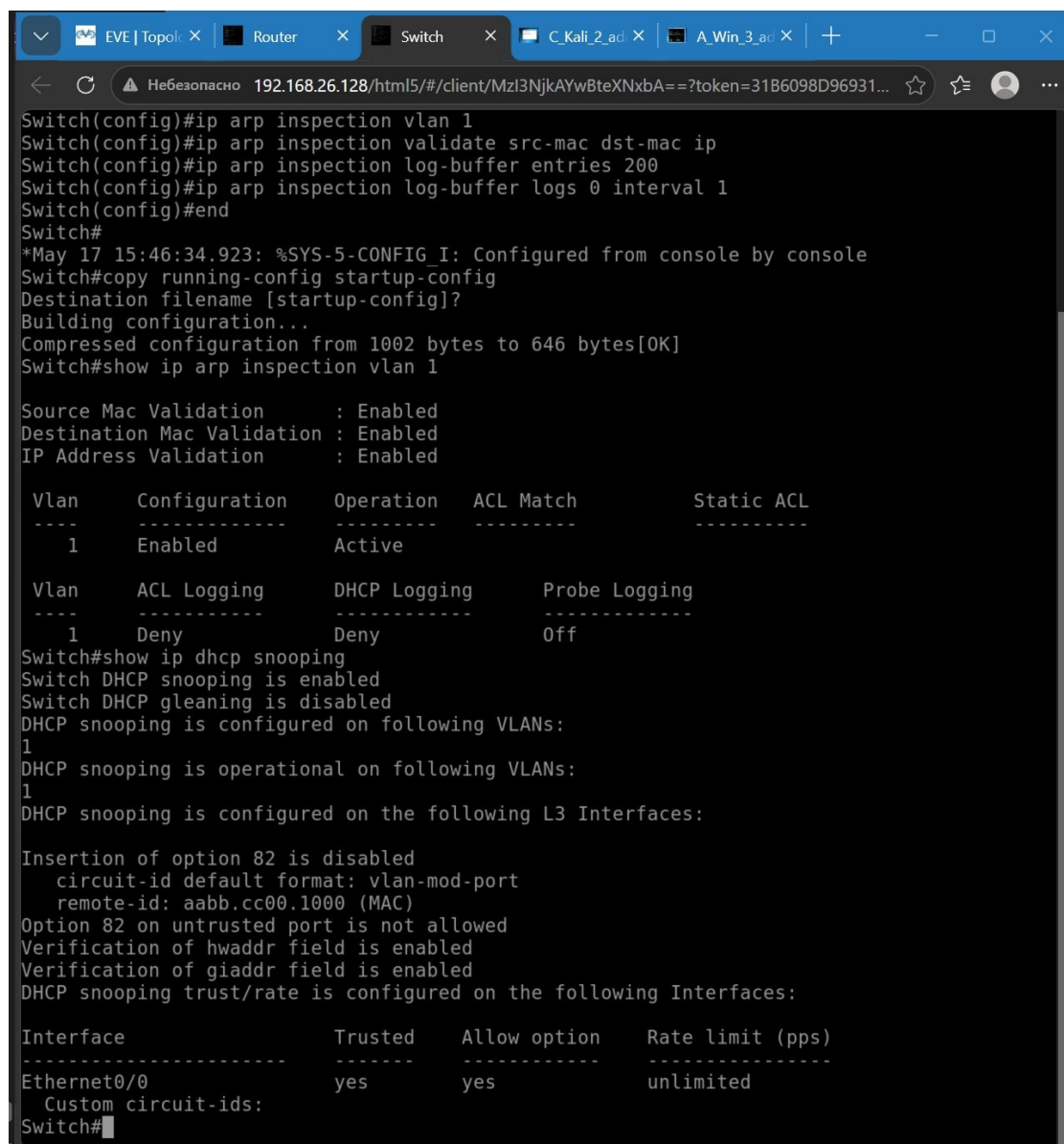
Switch#show ip dhcp snooping binding
MacAddress      IPAddress      Lease(sec)      Type            VLAN      Interface
-----
50:00:00:03:00:00  192.168.1.2    86303           dhcp-snooping   1         Ethernet0/2
00:50:00:00:02:00  192.168.1.3    86369           dhcp-snooping   1         Ethernet0/1
Total number of bindings: 2

Switch#show ip dhcp snooping statistics
Packets Forwarded           = 5
Packets Dropped              = 5
Packets Dropped From untrusted ports = 5
Switch#
  
```

Рис. 5. База данных сопоставлений DHCP Snooping и статистика коммутатора

Настройка динамической проверки ARP

На коммутаторе Switch командой `ip arp inspection vlan 1` механизм динамической проверки ARP был включён для VLAN 1. В отличие от лабораторной работы №4.1, статический список контроля доступа ARP не создавался: в среде с использованием протокола DHCP механизм DAI опирается на содержимое базы данных сопоставлений DHCP Snooping. Дополнительно командой `ip arp inspection validate src-mac dst-mac ip` была активирована расширенная проверка корректности кадров ARP (аналогично лабораторной работе №4.1), командами `ip arp inspection log-buffer entries 200` и `ip arp inspection log-buffer logs 0 interval 1` — настроен журнал событий механизма. Конфигурация и текущее состояние процесса динамической проверки ARP подтверждены командой `show ip arp inspection vlan 1` (рис. 6).



```
Switch(config)#ip arp inspection vlan 1
Switch(config)#ip arp inspection validate src-mac dst-mac ip
Switch(config)#ip arp inspection log-buffer entries 200
Switch(config)#ip arp inspection log-buffer logs 0 interval 1
Switch(config)#end
Switch#
*May 17 15:46:34.923: %SYS-5-CONFIG I: Configured from console by console
Switch#copy running-config startup-config
Destination filename [startup-config]?
Building configuration...
Compressed configuration from 1002 bytes to 646 bytes[OK]
Switch#show ip arp inspection vlan 1

Source Mac Validation      : Enabled
Destination Mac Validation: Enabled
IP Address Validation      : Enabled

Vlan    Configuration    Operation    ACL Match    Static ACL
----    -
1       Enabled          Active

Vlan    ACL Logging    DHCP Logging    Probe Logging
----    -
1       Deny           Deny           Off

Switch#show ip dhcp snooping
Switch DHCP snooping is enabled
Switch DHCP gleaning is disabled
DHCP snooping is configured on following VLANs:
1
DHCP snooping is operational on following VLANs:
1
DHCP snooping is configured on the following L3 Interfaces:

Insertion of option 82 is disabled
  circuit-id default format: vlan-mod-port
  remote-id: aabb.cc00.1000 (MAC)
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Verification of giaddr field is enabled
DHCP snooping trust/rate is configured on the following Interfaces:

Interface                Trusted    Allow option    Rate limit (pps)
-----
Ethernet0/0              yes       yes             unlimited
Custom circuit-ids:
Switch#
```

Рис. 6. Статус динамической проверки ARP и DHCP Snooping на коммутаторе

Генерация и фильтрация аномальных сообщений ARP и DHCP

Аномальный ARP-запрос. На узле С средствами утилиты arping было сформировано и отправлено аномальное широковещательное сообщение ARP-запроса командой `arping 192.168.1.2 -S 192.168.1.3 -s aa:aa:aa:aa:aa:aa`. Указанное сообщение противоречит легитимным сопоставлениям IP- и MAC-адресов, зарегистрированным в базе данных DHCP Snooping коммутатора, так как пара адресов источника (192.168.1.3, aa:aa:aa:aa:aa:aa) не соответствует записи (192.168.1.3, 00:50:00:00:02:00). Ответы от узла А не поступали (рис. 7).

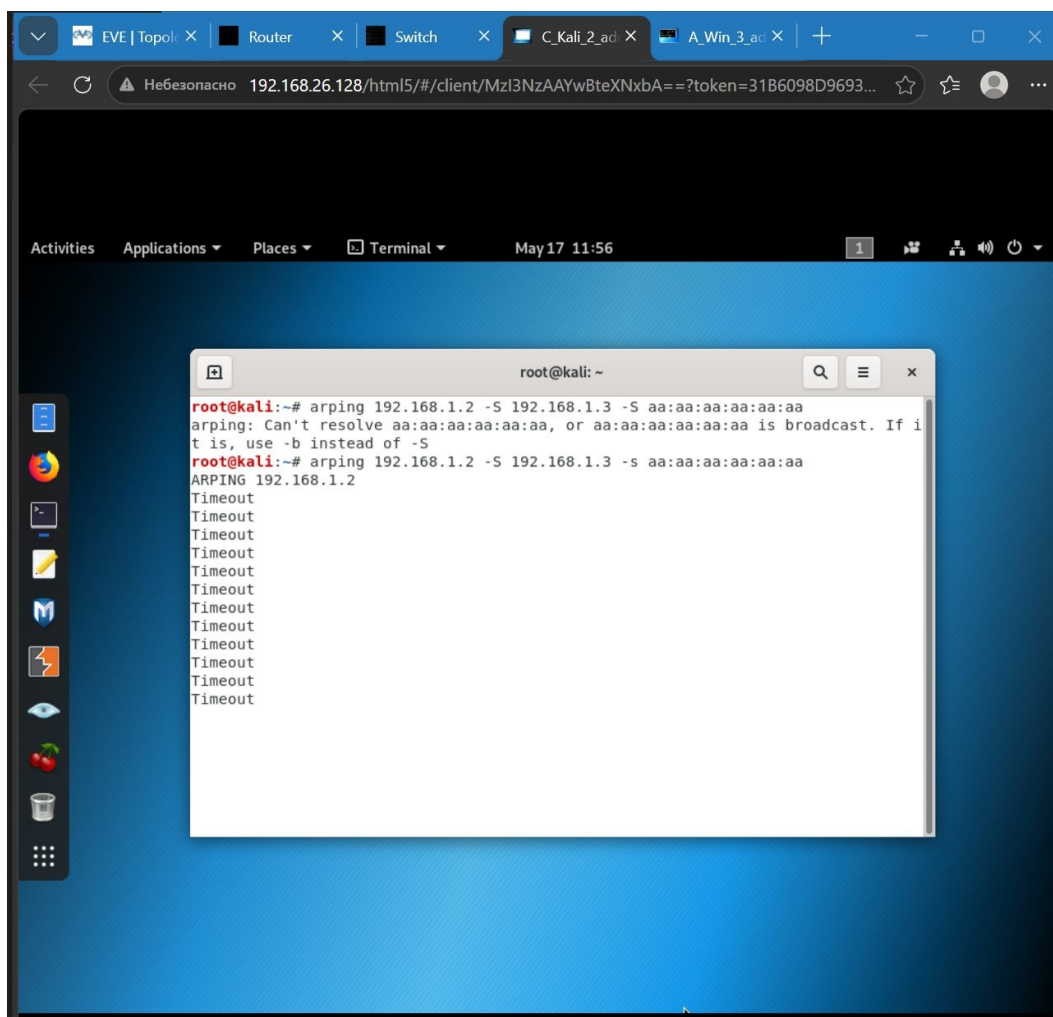


Рис. 7. Отправка аномального ARP-запроса на узле С

Командой `show ip arp inspection statistics vlan 1` была получена статистика отфильтрованных ARP-сообщений (рис. 8). Зафиксировано 49 отброшенных кадров, все из которых попали в счётчик DHCP Drops — в отличие от лабораторной работы №4.1, где аналогичный трафик отбрасывался в счётчик ACL Drops. Указанное поведение отражает принципиальное отличие механизма DAI в среде с использованием DHCP: проверка ARP-сообщений выполняется не на основании статического списка контроля доступа, а на основании содержимого базы данных сопоставлений, динамически наполняемой механизмом DHCP Snooping. В счётчики DHCP Permits и Forwarded также внесён небольшой прирост, соответствующий легитимному ARP-трафику между узлом А и маршрутизатором, прошедшему без фильтрации.


```
Switch#enable
Switch#show ip dhcp snooping binding
MacAddress      IPAddress      Lease(sec)    Type          VLAN  Interface
-----
00:50:00:00:02:00 192.168.1.3    86361         dhcp-snooping 1     Ethernet0/1
Total number of bindings: 1

Switch#enable
Switch#show ip dhcp snooping binding
MacAddress      IPAddress      Lease(sec)    Type          VLAN  Interface
-----
00:50:00:00:02:00 192.168.1.3    86351         dhcp-snooping 1     Ethernet0/1
Total number of bindings: 1

Switch#show ip dhcp snooping binding
MacAddress      IPAddress      Lease(sec)    Type          VLAN  Interface
-----
00:50:00:00:02:00 192.168.1.3    86321         dhcp-snooping 1     Ethernet0/1
Total number of bindings: 1

Switch#show ip dhcp snooping binding
MacAddress      IPAddress      Lease(sec)    Type          VLAN  Interface
-----
50:00:00:03:00:00 192.168.1.2    86382         dhcp-snooping 1     Ethernet0/2
00:50:00:00:02:00 192.168.1.3    86230         dhcp-snooping 1     Ethernet0/1
Total number of bindings: 2

Switch#clear ip arp inspection statistics vlan 1
Switch#show ip arp inspection statistics vlan 1

Vlan    Forwarded    Dropped    DHCP Drops    ACL Drops
-----
1       6            49         49            0

Vlan    DHCP Permits    ACL Permits    Probe Permits    Source MAC Failures
-----
1       3              0             0              0

Vlan    Dest MAC Failures    IP Validation Failures    Invalid Protocol Data
-----
1       0                   0                        0
```

Рис. 8. Статистика фильтрации аномальных ARP-сообщений механизмом DHCP Snooping

Атака истощения ресурсов легитимного DHCP-сервера. На узле С было запущено программное обеспечение Yersinia в интерактивном режиме командой yersinia -I, в режиме DHCP инициирован запуск атаки sending DISCOVER packet последовательным нажатием клавиш «х» и «1». Yersinia начала формировать и отправлять множественные запросы DHCPDISCOVER с произвольными MAC-адресами источника, имитируя большое количество новых клиентов локальной сети. За время наблюдения за атакой Yersinia зафиксировала отправку 1 447 690 пакетов протокола DHCP (рис. 9).

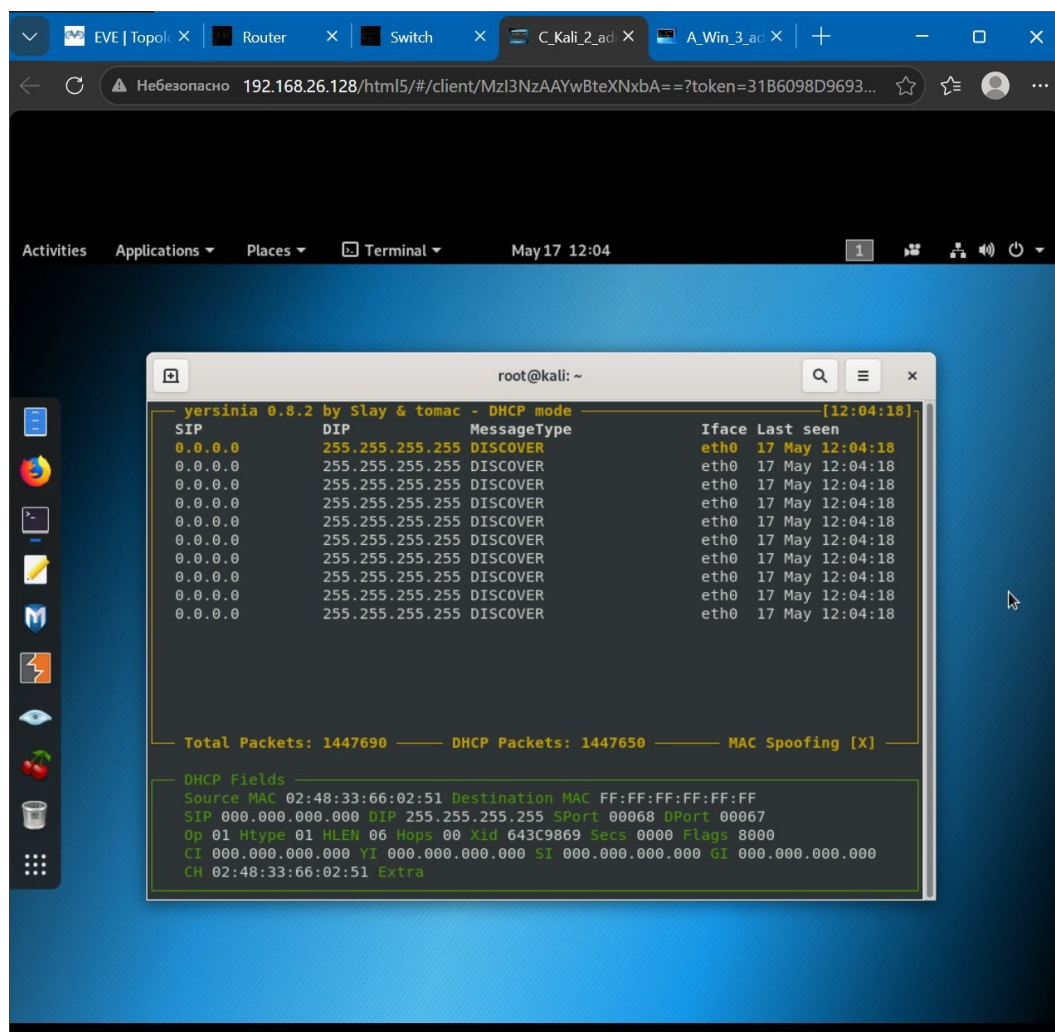
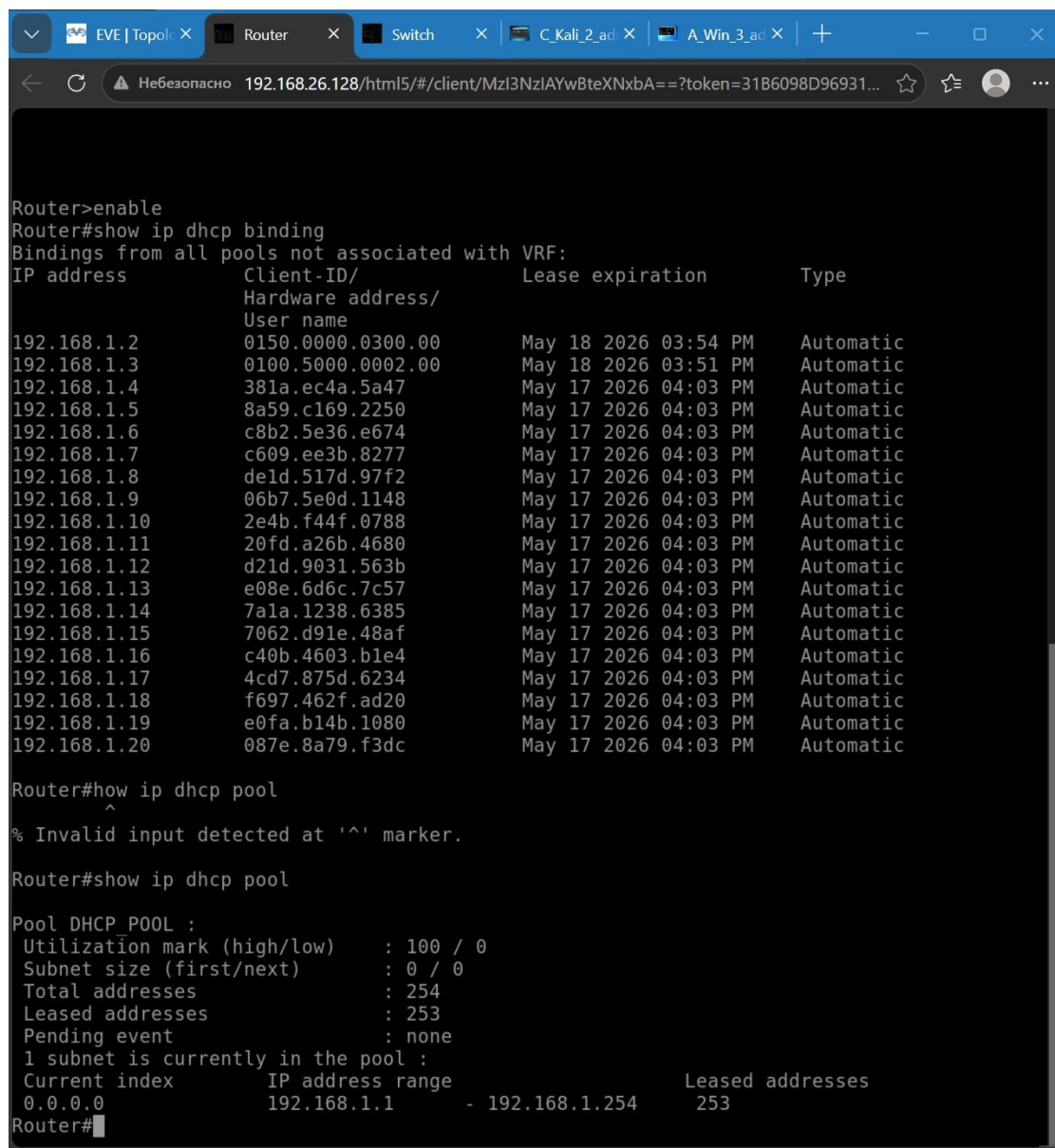


Рис. 9. Атака истощения ресурсов DHCP-сервера, запущенная утилитой Yersinia

В отличие от ожидаемого по методическим указаниям поведения (полная фильтрация атаки механизмом DHCP Snooping), в реальных условиях лабораторной среды EVE-NG был зафиксирован ряд отклонений, связанных с особенностями программной эмуляции коммутатора Cisco. Образ Cisco IOL, использовавшийся в работе вместо аппаратного коммутатора Cisco Catalyst 2960, реализует механизм DHCP Snooping программно, без аппаратной поддержки ограничения скорости DHCP-кадров на недоверенных портах. В результате под нагрузкой в 1 447 690 DHCP-пакетов коммутатор Switch не справился с обработкой трафика и ушёл в самопроизвольную перезагрузку. До момента перезагрузки часть запросов DHCPDISCOVER достигла маршрутизатора-DHCP-сервера, что привело к частичному истощению пула:

командой `show ip dhcp pool` на маршрутизаторе было зафиксировано 253 выданных адреса из 254 доступных (рис. 10).



```
Router>enable
Router#show ip dhcp binding
Bindings from all pools not associated with VRF:
IP address      Client-ID/      Lease expiration        Type
                Hardware address/
                User name
192.168.1.2      0150.0000.0300.00    May 18 2026 03:54 PM    Automatic
192.168.1.3      0100.5000.0002.00    May 18 2026 03:51 PM    Automatic
192.168.1.4      381a.ec4a.5a47       May 17 2026 04:03 PM    Automatic
192.168.1.5      8a59.c169.2250       May 17 2026 04:03 PM    Automatic
192.168.1.6      c8b2.5e36.e674       May 17 2026 04:03 PM    Automatic
192.168.1.7      c609.ee3b.8277       May 17 2026 04:03 PM    Automatic
192.168.1.8      de1d.517d.97f2       May 17 2026 04:03 PM    Automatic
192.168.1.9      06b7.5e0d.1148       May 17 2026 04:03 PM    Automatic
192.168.1.10     2e4b.f44f.0788       May 17 2026 04:03 PM    Automatic
192.168.1.11     20fd.a26b.4680       May 17 2026 04:03 PM    Automatic
192.168.1.12     d21d.9031.563b       May 17 2026 04:03 PM    Automatic
192.168.1.13     e08e.6d6c.7c57       May 17 2026 04:03 PM    Automatic
192.168.1.14     7a1a.1238.6385       May 17 2026 04:03 PM    Automatic
192.168.1.15     7062.d91e.48af       May 17 2026 04:03 PM    Automatic
192.168.1.16     c40b.4603.b1e4       May 17 2026 04:03 PM    Automatic
192.168.1.17     4cd7.875d.6234       May 17 2026 04:03 PM    Automatic
192.168.1.18     f697.462f.ad20       May 17 2026 04:03 PM    Automatic
192.168.1.19     e0fa.b14b.1080       May 17 2026 04:03 PM    Automatic
192.168.1.20     087e.8a79.f3dc       May 17 2026 04:03 PM    Automatic

Router#how ip dhcp pool
^
% Invalid input detected at '^' marker.

Router#show ip dhcp pool

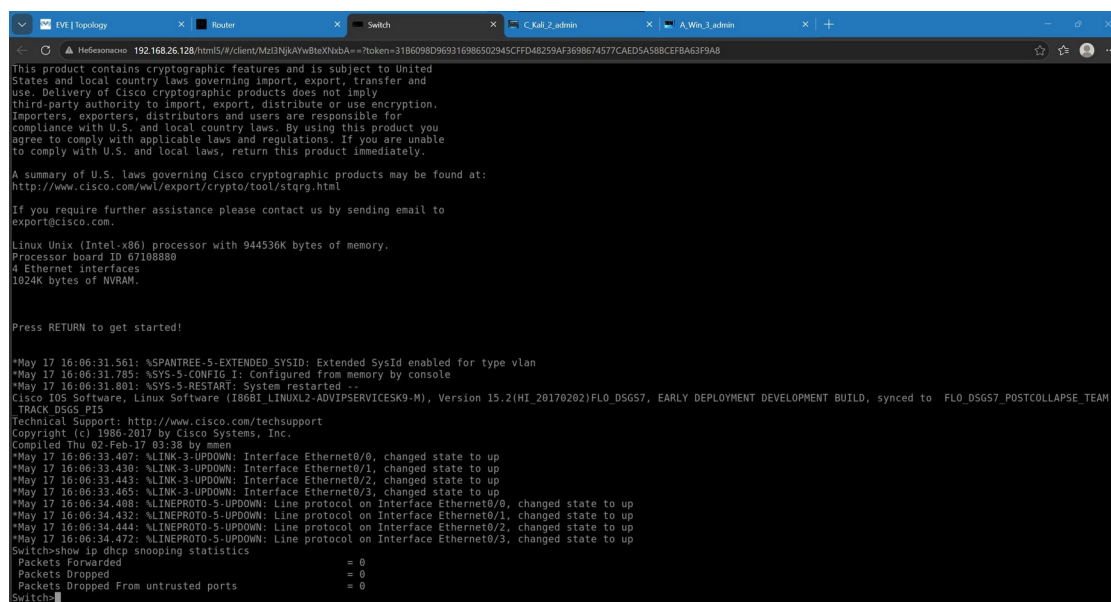
Pool DHCP POOL :
  Utilization mark (high/low)      : 100 / 0
  Subnet size (first/next)          : 0 / 0
  Total addresses                    : 254
  Leased addresses                  : 253
  Pending event                     : none
  1 subnet is currently in the pool :
    Current index    IP address range    Leased addresses
    0.0.0.0          192.168.1.1 - 192.168.1.254    253

Router#
```

Рис. 10. Состояние пула DHCP-сервера после атаки истощения

Указанное отступление от методических указаний носит технический характер и не противоречит общему принципу работы DHCP Snooping: на реальном оборудовании Cisco Catalyst 2960 ограничение скорости DHCP-кадров на недоверенных портах реализуется аппаратно и обеспечивает блокирование указанной атаки до её достижения DHCP-сервера. После рестарта коммутатора, инициированного перегрузкой, конфигурация DHCP Snooping и Dynamic ARP

Inspection была автоматически восстановлена из startup-config, что подтверждено выводом команд show ip arp inspection vlan 1 и show ip dhcp snooping (рис. 11). База данных сопоставлений DHCP Snooping после рестарта оказалась пустой, что также соответствует особенностям программной реализации механизма в указанном образе.



```

This product contains cryptographic features and is subject to United
States and local country laws governing import, export, transfer and
use. Delivery of Cisco cryptographic products does not imply
third-party authority to import, export, distribute or use encryption.
Importers, exporters, distributors and users are responsible for
compliance with U.S. and local country laws. By using this product you
agree to comply with applicable laws and regulations. If you are unable
to comply with U.S. and local laws, return this product immediately.

A summary of U.S. laws governing Cisco cryptographic products may be found at:
http://www.cisco.com/wll/export/crypto/tool/stqrg.html

If you require further assistance please contact us by sending email to
export@cisco.com.

Linux Unix (Intel x86) processor with 944536K bytes of memory.
Processor board ID 07108880
4 Ethernet interfaces
1024K bytes of NVRAM.

Press RETURN to get started!

*May 17 16:06:31.561: %SPANTREE-5-EXTENDED SysId: Extended SysId enabled for type vlan
*May 17 16:06:31.785: %SYS-5-CONFIG I: Configured from memory by console
*May 17 16:06:31.801: %SYS-5-RESTART: System restarted
Cisco IOS Software, Linux Software (18081_LINUX12-ADVIPSERVICESK9-M), Version 15.2(HI_20170202)FLO_DS657, EARLY DEPLOYMENT DEVELOPMENT BUILD, synced to FLO_DS657_POSTCOLLAPSE_TEAM
TRACK_DS65_P15
Technical Support: http://www.cisco.com/techsupport
Copyright (c) 1986-2017 by Cisco Systems, Inc.
Compiled Thu 02-Feb-17 03:38 by mmen
*May 17 16:06:33.407: %LINK-3-UPDOWN: Interface Ethernet0/0, changed state to up
*May 17 16:06:33.430: %LINK-3-UPDOWN: Interface Ethernet0/1, changed state to up
*May 17 16:06:33.443: %LINK-3-UPDOWN: Interface Ethernet0/2, changed state to up
*May 17 16:06:33.465: %LINK-3-UPDOWN: Interface Ethernet0/3, changed state to up
*May 17 16:06:34.408: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/0, changed state to up
*May 17 16:06:34.432: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/1, changed state to up
*May 17 16:06:34.444: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/2, changed state to up
*May 17 16:06:34.472: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/3, changed state to up
Switch#show ip dhcp snooping statistics
Packets Forwarded                = 0
Packets Dropped                  = 0
Packets Dropped From untrusted ports = 0
Switch#
```

Рис. 11. Состояние коммутатора после восстановления из startup-config

Для продолжения экспериментов пул DHCP-сервера был пересоздан, база данных сопоставлений освобождена, после чего на узлах А и С командами ipconfig /release, ipconfig /renew и dhclient -r eth0, dhclient eth0 был выполнен повторный запрос IP-адресов. В результате узлам были выданы те же IP-адреса, что и в начале лабораторной работы (192.168.1.2 узлу А и 192.168.1.3 узлу С), база данных DHCP Snooping наполнена двумя легитимными записями.

Атака с размещением фиктивного DHCP-сервера. На узле С средствами Yersinia в режиме DHCP последовательным нажатием клавиш «х» и «2» был инициирован запуск атаки creating DHCP rogue server. В окне конфигурации фиктивного DHCP-сервера были заданы параметры, противоречащие легитимной конфигурации сети: идентификатор сервера 192.168.1.10, диапазон выдаваемых адресов 192.168.1.100–192.168.1.200, адрес шлюза 192.168.1.10,

DNS-сервер 8.8.8.8, доменное имя mydomain.com (рис. 12). Указанные параметры приведут к тому, что в случае успеха атаки трафик узла-жертвы будет маршрутизироваться через атакующий узел С, что сделает возможным перехват трафика.

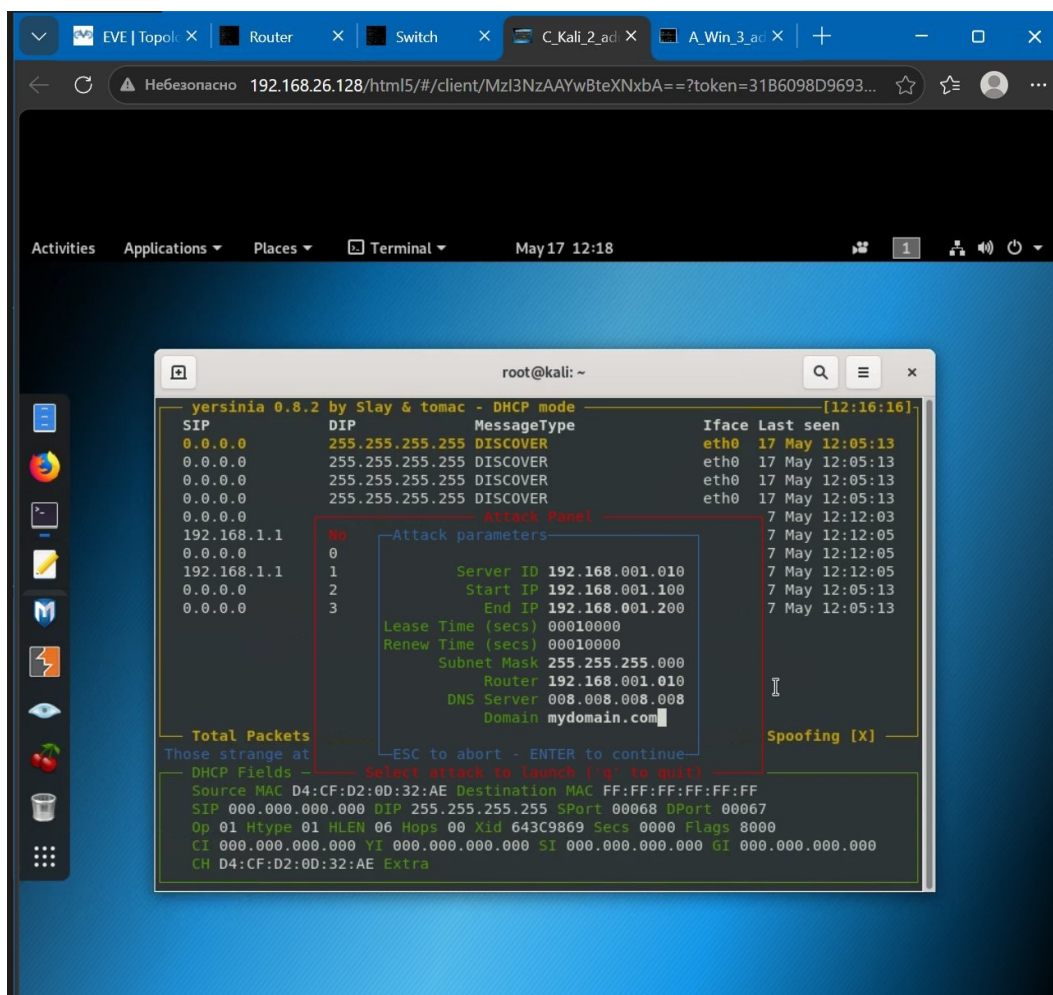


Рис. 12. Параметры фиктивного DHCP-сервера, задаваемые в Yersinia

Для проверки эффективности механизма DHCP Snooring на узле А было выполнено принудительное обновление IP-адреса командами `ipconfig /release` и `ipconfig /renew`. По итогам обмена с DHCP-сервером командой `ipconfig` зафиксированы следующие сетевые параметры узла А: IP-адрес 192.168.1.2, маска подсети 255.255.255.0, шлюз по умолчанию 192.168.1.1, доменное имя my-domain.com (рис. 13). Получены легитимные параметры от DHCP-сервера на маршрутизаторе Router, не параметры от фиктивного DHCP-сервера Yersinia.

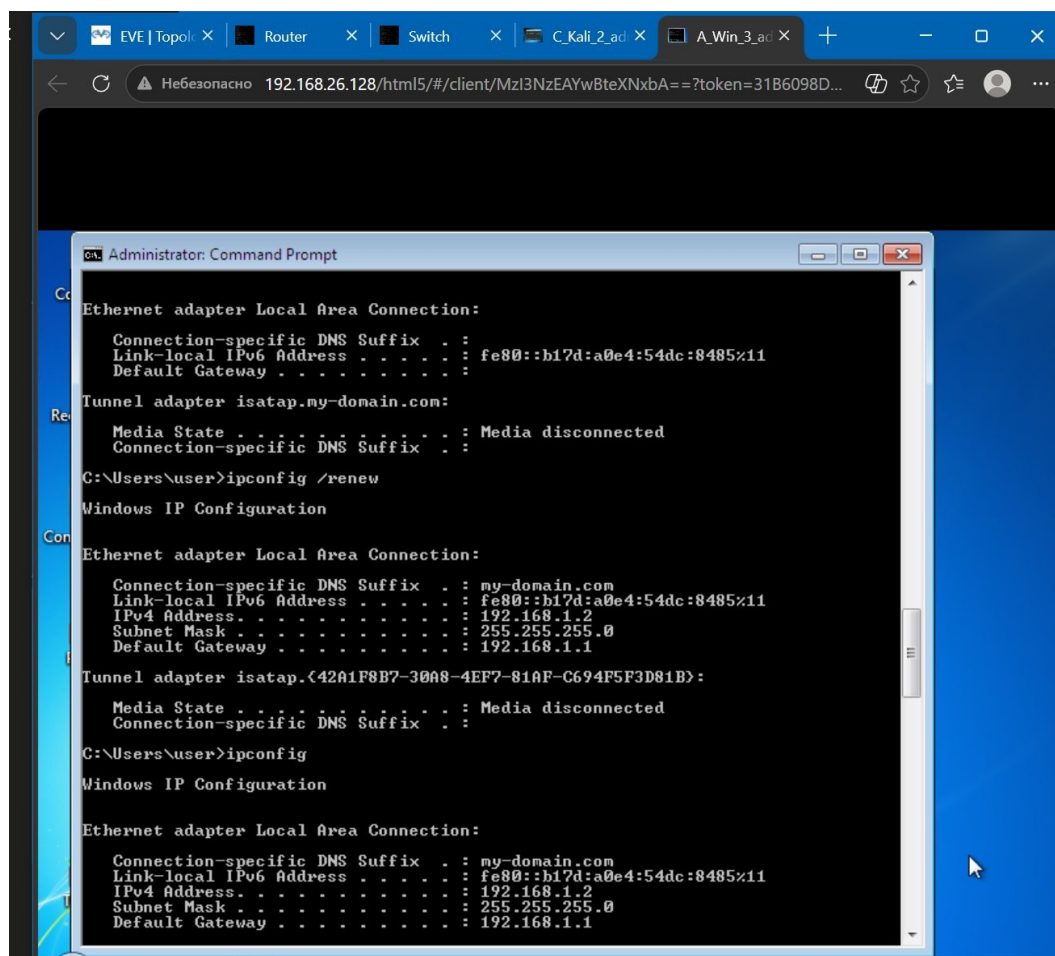


Рис. 13. Сетевые параметры узла А после атаки с размещением фиктивного DHCP-сервера

Командой `show ip dhcp snooping statistics` на коммутаторе была получена статистика работы механизма DHCP Snooping (рис. 14). Зафиксирован прирост счётчика `Packets Dropped From untrusted ports` на 4 единицы по сравнению с замером до атаки (с 5 до 9), что соответствует кадрам DHCP OFFER, отправленным фиктивным сервером Yersinia в ответ на запросы узла А. Все указанные кадры были отброшены коммутатором как поступившие с недоверенного интерфейса (Ethernet0/1, к которому подключён узел С). Поведение соответствует принципу работы DHCP Snooping: на недоверенных интерфейсах разрешено получение от хоста только сообщений типа DHCPDISCOVER, DHCPREQUEST и DHCPRELEASE, тогда как сообщения DHCPOFFER и DHCPACK, формируемые DHCP-сервером, разрешены исключительно на доверенных портах.

```
-----
1      Deny      Deny      Off
Switch#show ip dhcp snooping
Switch DHCP snooping is enabled
Switch DHCP gleaning is disabled
DHCP snooping is configured on following VLANs:
1
DHCP snooping is operational on following VLANs:
1
DHCP snooping is configured on the following L3 Interfaces:

Insertion of option 82 is disabled
  circuit-id default format: vlan-mod-port
  remote-id: aabb.cc00.1000 (MAC)
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Verification of giaddr field is enabled
DHCP snooping trust/rate is configured on the following Interfaces:

Interface              Trusted    Allow option    Rate limit (pps)
-----
Ethernet0/0            yes       yes             unlimited
  Custom circuit-ids:
Switch#show ip dhcp snooping binding
-----
Total number of bindings: 0

Switch#show ip dhcp snooping binding
-----
Total number of bindings: 2
50:00:00:03:00:00      192.168.1.2      86303      dhcp-snooping      1      Ethernet0/2
00:50:00:00:02:00      192.168.1.3      86369      dhcp-snooping      1      Ethernet0/1

Switch#show ip dhcp snooping statistics
Packets Forwarded      = 5
Packets Dropped         = 5
Packets Dropped From untrusted ports = 5
Switch#
Switch#show ip dhcp snooping statistics
Packets Forwarded      = 8
Packets Dropped         = 9
Packets Dropped From untrusted ports = 9
Switch#
```

Рис. 14. Статистика DHCP Snooping после атаки с размещением фиктивного DHCP-сервера

Вывод

В ходе выполнения лабораторной работы был изучен и практически применён механизм совместного использования функций безопасности Dynamic ARP Inspection и DHCP Snooping коммутаторов Cisco для обеспечения защиты локальной сети с использованием протокола DHCP от аномального трафика канального уровня. На коммутаторе был включён механизм DHCP Snooping глобально и для VLAN 1, порт подключения легитимного DHCP-сервера

обозначен в качестве доверенного, активирован механизм Dynamic ARP Inspection с расширенной проверкой корректности кадров без использования статического списка контроля доступа. После повторного получения узлами IP-адресов по протоколу DHCP коммутатор наполнил базу данных сопоставлений DHCP Snooping двумя легитимными записями, использовавшимися механизмом DAI для проверки корректности ARP-сообщений.

Экспериментально подтверждена эффективность работы Dynamic ARP Inspection в указанной среде: аномальные ARP-запросы с подменой пары IP- и MAC-адресов источника отбрасываются механизмом DHCP Drops по результатам сверки с базой данных сопоставлений DHCP Snooping, в отличие от среды без использования DHCP, где аналогичные сообщения фильтруются по статическому списку контроля доступа. Также подтверждена эффективность механизма DHCP Snooping в отношении атаки с размещением фиктивного DHCP-сервера: кадры DHCP OFFER, отправляемые узлом-нарушителем, отбрасываются коммутатором как поступившие с недоверенного порта, что не позволяет фиктивному DHCP-серверу подменить сетевые параметры узла-жертвы.

Также экспериментально были выявлены особенности программной реализации механизма DHCP Snooping в образе Cisco IOL, использовавшемся в качестве замены аппаратного коммутатора Cisco Catalyst 2960. В отличие от ожидаемого по методическим указаниям поведения, атака истощения ресурсов легитимного DHCP-сервера посредством отправки множественных запросов DHCPDISCOVER не была полностью нейтрализована: под нагрузкой более 1,4 миллиона пакетов коммутатор ушёл в самопроизвольную перезагрузку, до момента которой 253 из 254 адресов пула были выданы фиктивным клиентам. Указанное отступление от методических указаний связано с программной природой эмуляции коммутатора в среде EVE-NG, не обеспечивающей аппаратное ограничение скорости DHCP-кадров на недоверенных портах, и не

противоречит общему принципу работы DHCP Snooping на реальном оборудовании Cisco Catalyst.

В процессе выполнения лабораторной работы практически продемонстрирована способность коммутатора Cisco при корректной настройке Dynamic ARP Inspection и DHCP Snooping обнаруживать и предотвращать как аномальный ARP-трафик, направленный на повреждение ARP-таблиц узлов сети, так и аномальный DHCP-трафик, направленный на подмену сетевых параметров узлов-жертв путём размещения фиктивного DHCP-сервера.

Контрольные вопросы

5. Как используется заголовок кадров Ethernet при проверке ARP-сообщений?

Заголовок кадров Ethernet используется коммутатором при выполнении дополнительной проверки корректности ARP-сообщений механизмом Dynamic ARP Inspection в режиме расширенной валидации, активируемой командой `ip arp inspection validate src-mac dst-mac ip`. Логика проверки заключается в следующем: при инкапсуляции сообщения ARP в кадр Ethernet MAC-адреса источника и назначения присутствуют в двух местах одновременно — в заголовке Ethernet-кадра (поля Source MAC и Destination MAC) и в самом ARP-сообщении внутри Ethernet-кадра (поля Sender Hardware Address и Target Hardware Address). При штатной работе протокола указанные значения должны совпадать: MAC-адрес источника в Ethernet-заголовке — со значением Sender Hardware Address в ARP-payload, MAC-адрес назначения (для ARP-ответов) — со значением Target Hardware Address. Несоответствие указанных значений свидетельствует о намеренной подмене заголовков и обнаруживается коммутатором: проверка `src-mac` срабатывает на запросах и ответах ARP, проверка `dst-mac` — только на ответах ARP. По результатам проверки аномальный кадр отбрасывается и регистрируется в журнале коммутатора,

соответствующий счётчик статистики (Source MAC Failures или Destination MAC Failures) увеличивается. Указанный механизм был практически задействован в Сообщении №4 лабораторной работы №4.1: аномальный ARP-ответ, сформированный средствами Scapy с несовпадающими значениями MAC-адреса источника в Ethernet- и ARP-заголовках, был отброшен коммутатором с увеличением счётчика Source MAC Failures на 30 единиц по числу отправленных кадров.

6. Как можно определить количество сообщений ARP, отфильтрованных на коммутаторе, в результате динамической проверки ARP?

Количество отфильтрованных сообщений ARP можно определить на коммутаторе Cisco командой `show ip arp inspection statistics vlan <vlan-id>`, выводящей таблицу со счётчиками работы механизма Dynamic ARP Inspection для указанной VLAN. Таблица включает общее число отброшенных кадров (Dropped) и пропущенных кадров (Forwarded), а также детализацию причин фильтрации по отдельным механизмам: ACL Drops — отброшено по правилам статического списка контроля доступа ARP (применяется в среде без использования DHCP, рассмотрено в лабораторной работе №4.1); DHCP Drops — отброшено по результатам сверки с базой данных сопоставлений DHCP Snooping (применяется в среде с использованием DHCP, рассмотрено в лабораторной работе №4.2); Source MAC Failures и Destination MAC Failures — отброшено из-за несоответствия MAC-адресов в заголовках Ethernet и ARP; IP Validation Failures — отброшено из-за наличия недействительных IP-адресов в заголовке ARP-сообщения; Invalid Protocol Data — отброшено из-за нарушения формата ARP-сообщения. Для обнуления указанных счётчиков (необходимого, например, для измерения прироста по результатам конкретной атаки) используется команда `clear ip arp inspection statistics vlan <vlan-id>`. Для просмотра общего статуса и конфигурации механизма используется команда `show ip arp inspection vlan <vlan-id>`. Дополнительно события фильтрации с

детализацией параметров каждого отфильтрованного кадра (MAC-адресов и IP-адресов источника и назначения, интерфейса и временной метки) регистрируются в журнале коммутатора в виде записей с идентификаторами %SW_DAI-4-ACL_DENY, %SW_DAI-4-DHCP_SNOOPING_DENY и %SW_DAI-4-INVALID_ARP, доступных через стандартный вывод консоли коммутатора или через буфер логирования посредством команды show logging.